Title of the project : Zero Trust Network Access (ZTNA) with Zscaler: Securing User-to-Application Connectivity.

Abstract

Zero Trust Network Access (ZTNA) is a modern security model that protects organizational resources by ensuring that no user or device is trusted by default, even if they are inside the network. This approach verifies every access request based on identity, device health, and security policies before allowing users to connect to applications. As organizations increasingly adopt cloud services and remote work environments, traditional network security models become less effective.

Zscaler provides a cloud-based platform that enables organizations to implement ZTNA efficiently. By using Zscaler's secure access solutions, users connect directly to applications rather than the corporate network, reducing the risk of unauthorized access and lateral movement by attackers. The platform continuously monitors user activity and enforces security policies to ensure that only authorized users can access specific applications.

This paper discusses the implementation of ZTNA using Zscaler to secure user-to-application connectivity. It highlights the architecture, key components, and operational workflow of the solution. The study also examines the benefits of ZTNA, including improved security, reduced attack surface, enhanced visibility, and better support for remote work. By adopting Zscaler-based ZTNA, organizations can strengthen their cybersecurity posture while maintaining seamless and secure access to applications for users.

Overview :

Zero Trust Network Access (ZTNA) with Zscaler: Securing User-to-Application Connectivity

The project “Zero Trust Network Access (ZTNA) with Zscaler: Securing User-to-Application Connectivity” focuses on improving cybersecurity in modern organizations by implementing the Zero Trust security model. In today’s digital world, many companies allow employees to access applications and data from different locations such as offices, homes, or public networks. Traditional security systems mainly depend on Virtual Private Networks (VPNs) to provide remote access. However, VPNs can expose the internal network to security risks because once a user is connected, they may gain broad access to multiple resources inside the network. This increases the chances of cyberattacks, unauthorized access, and data breaches.

The idea of this project is to implement a Zero Trust Network Access (ZTNA) approach using the cloud-based security platform provided by Zscaler. The Zero Trust model follows the principle “Never trust, always verify.” This means that no user or device is automatically trusted, even if they are inside the organization’s network. Every access request must be verified based on identity, device security status, and organizational policies before permission is granted.

In this project, ZTNA technology is used to provide secure and direct connectivity between users and specific applications without exposing the entire internal network. Instead of connecting users to the full network like a VPN, the system connects them only to the application they are authorized to access. This reduces the attack surface and prevents attackers from moving freely within the network if a device is compromised.

The Zscaler platform acts as a secure cloud gateway that manages and verifies user access. When a user attempts to access an application, the request is first sent to the Zscaler cloud platform. The platform checks the user’s identity through authentication systems such as corporate directories or identity providers. It also evaluates security policies, device posture, and access permissions. If all conditions are satisfied, the user is granted a secure connection to the specific application. If the request does not meet security requirements, access is denied.

Another important idea behind this project is application segmentation. This means that users can access only the applications required for their work. For example, an employee in the finance department may only be able to access financial systems, while a developer may access development tools. This approach limits unauthorized access and reduces the risk of insider threats.

The project also highlights how cloud-based security solutions are becoming important in modern IT environments. With the increasing use of cloud services, mobile devices, and remote work, organizations need flexible and scalable security solutions. ZTNA with Zscaler provides centralized management, improved visibility of user activity, and stronger protection against cyber threats such as phishing, malware, and unauthorized network access.

Overall, the main idea of this project is to demonstrate how Zero Trust architecture can replace traditional network security models and provide a safer way for users to access enterprise applications. By using ZTNA technology through Zscaler, organizations can ensure that every connection is authenticated, authorized, and continuously monitored. This project shows how modern cybersecurity strategies can protect sensitive data, support secure remote work, and improve the overall security posture of an organization.

List of teammates–

S.no	name	college	contact
1	VIJAY KRISHNAN S	Sri Krishna Adithya college of arts and science	23bsca167vijaykrishnans@skacas.ac.in
2	SUDHEENDAR PK	Sri Krishna Adithya college of arts and science	23bsca159sudheedarpk@skacas.ac.in
3	KISHORE KUMAR B	Sri Krishna Adithya college of arts and science	23bsca137kishorekumarb@skacas.ac.in
4	JEEVANANTHAM D	Sri Krishna Adithya college of arts and science	23bsca132jeevananthamd@skacas.ac.in

List of Vulnerability Table

S.no	Vulnerability Name	CWE/CVE - No
1	Security Misconfiguration	CWE-16
2	Broken Access control	CWE-22
3	Software supply chain failure	CWE-447
4	Injection	CWE-20
	Insecure Design	CWE-73
5	Authentication Failures	CWE-258
6	Mishandling of Exceptional Conditions	CWE-209
7	Security Logging & Alerting Failures	CWE-117
8	Software or Data Integrity Failures	CWE-345

9 10	**Cryptographic Failures**	**CWE-261**

REPORT:-

Vulnerability Name:- Configuration

CWE/CVE : - CWE-16

OWASP/SANS Category:- A02:2025 Security Misconfiguration

Description:- Security Misconfiguration occurs when systems, applications, servers, databases, or cloud services are improperly configured, leaving them vulnerable to unauthorized access or cyberattacks. This vulnerability happens when default settings are not changed, unnecessary services are enabled, security features are disabled, or sensitive information is exposed due to incorrect configuration.

In many systems, default configurations are designed for easy installation and usability rather than strong security. If administrators fail to properly configure security settings, attackers may exploit these weaknesses to gain access to confidential data, modify system settings, or disrupt services.

Examples of security misconfiguration include:

- Using default usernames and passwords.
- Exposing administrative interfaces to the internet.
- Incorrect access control permissions.
- Unpatched or outdated software components.
- Enabled debugging or error messages revealing system information.
- Improper cloud storage permissions.

In the context of Zero Trust Network Access (ZTNA) using Zscaler, configuration vulnerabilities may occur if security policies, identity authentication settings, or access controls are not properly implemented. This could allow unauthorized users to access internal applications or sensitive resources.

Security misconfiguration is considered one of the most common vulnerabilities because it can occur at multiple layers such as operating systems, web servers, databases, network devices, and cloud platforms.

Business Impact:

Security misconfiguration can cause serious risks for organizations and may lead to several negative impacts:

1. **Unauthorized Access**
   Attackers may gain access to internal systems, applications, or sensitive data due to weak or incorrect security settings.

2. **Data Breaches**
   Misconfigured systems can expose confidential information such as customer data, financial records, and company secrets.

3. **Financial Loss**
   Organizations may face financial damage due to data theft, regulatory penalties, legal costs, and incident recovery expenses.

4. **Service Disruption**
   Improper configuration can allow attackers to exploit vulnerabilities and cause system downtime or denial-of-service attacks.

5. **Reputation Damage**
   If a security breach occurs due to misconfiguration, it can harm the company's reputation and reduce customer trust.

6. **Compliance Violations**
   Organizations may fail to meet security regulations and standards, leading to penalties and legal issues.

Vulnerability Name:- Broken Access Control

CWE/CVE : - CWE-22

OWASP/SANS Category:- A01:2025 Broken Access Control

Description: Broken Access Control is a security vulnerability that occurs when an application **fails to properly enforce restrictions on what authenticated users are allowed to do**. Access control mechanisms are designed to ensure that users can only access the resources, data, or functions that they are authorized to use. When these controls are weak or incorrectly implemented, attackers may bypass restrictions and gain unauthorized access to sensitive information or system functions.

This vulnerability often happens when applications rely on client-side controls, weak authorization checks, or incorrect configuration of permissions. For example, a normal user may be able to access administrative pages, modify other users' data, or retrieve confidential files by manipulating URLs, parameters, or requests.

In the context of systems secured through **Zscaler Zero Trust Network Access (ZTNA)**, broken access control can occur if access policies are not correctly configured. For instance, if identity-based rules are misconfigured, a user might gain access to applications or data that should only be available to specific roles or departments. This weakens the Zero Trust model, which depends on strict verification and authorization for every access request.

Common examples of broken access control include:

- Accessing restricted pages without proper authorization
- Modifying another user's data or account
- Viewing sensitive files or directories
- Privilege escalation (gaining admin access)
- Bypassing role-based restrictions

Broken Access Control is considered one of the **most critical web security vulnerabilities** because it directly exposes protected resources to unauthorized users.

Business Impact:

Security misconfiguration can cause serious risks for organizations and may lead to several negative impacts:

1. Unauthorized Access

Attackers may gain access to internal systems, applications, or sensitive data due to weak or incorrect security settings.

2. Data Breaches

Misconfigured systems can expose confidential information such as customer data, financial records, and company secrets.

3. Financial Loss

Organizations may face financial damage due to data theft, regulatory penalties, legal costs, and incident recovery expenses.

4. Service Disruption

Improper configuration can allow attackers to exploit vulnerabilities and cause system downtime or denial-of-service attacks.

5. Reputation Damage

If a security breach occurs due to misconfiguration, it can harm the company's reputation and reduce customer trust.

6. Compliance Violations

Organizations may fail to meet security regulations and standards, leading to penalties and legal issues.

Vulnerability Name:- Software supply chain failure

CWE/CVE : - CWE-447

OWASP/SANS Category:- A03:2025 Software Supply Chain Failures

Description: Software Supply Chain Failure is a security vulnerability that occurs when third-party software components, libraries, tools, or services used in an application contain security weaknesses or malicious code. Modern applications often rely on external packages, frameworks, plugins, and open-source libraries to speed up development. If these components are not properly verified, monitored, or updated, they can introduce serious security risks into the system.

A software supply chain includes all elements involved in building and delivering software, such as code repositories, development tools, third-party dependencies, update servers, and deployment pipelines. If attackers compromise any part of this chain, they can inject malicious code or exploit vulnerabilities that affect many organizations using the same software.

For example, a developer may use an outdated or compromised library from an online repository. If that library contains a hidden vulnerability or malicious code, it can allow attackers to gain unauthorized access, steal data, or execute harmful actions within the system.

In enterprise environments using cloud security platforms like Zscaler, software supply chain risks can arise when applications integrate insecure third-party services or plugins without proper security validation. Attackers may exploit these weaknesses to bypass security controls or access sensitive resources.

Common causes of software supply chain failures include:

- Using outdated or vulnerable third-party libraries
- Downloading software from untrusted sources
- Lack of verification for software updates or patches

Business Impact:

1. Unauthorised Data Access

Attackers may access confidential information such as customer data,

financial records, or internal documents.

2. Data Manipulation or Deletion

Unauthorised users may modify or delete important data, which can

affect business operations and data integrity.

3. Financial Loss

Security breaches caused by broken access control can lead to

financial damage due to recovery costs, legal penalties, and loss of

business opportunities.

4. Privacy Violations

Sensitive customer information may be exposed, violating privacy

regulations and compliance standards.

5. System Abuse and Privilege Escalation

Attackers may gain administrative privileges and control critical

systems or applications.

6. Damage to Reputation

If customers' data is compromised, the organisation may lose trust

and credibility in the market.

Stage 2

Overview:

Nessus is a powerful vulnerability assessment and security scanning tool developed by **Tenable** to identify security weaknesses in computer systems, networks, servers, and applications. It is widely used by cybersecurity professionals, network administrators, and organizations to detect vulnerabilities before they can be exploited by attackers. Nessus scans target systems using a large database of regularly updated plugins that check for known vulnerabilities, missing security patches, outdated software versions, configuration issues, weak passwords, and malware threats. The tool performs both authenticated and unauthenticated scans to analyze system security from different perspectives. After completing the scanning process, Nessus generates detailed reports that classify vulnerabilities according to their severity levels such as low, medium, high, and critical, and it also provides recommendations and possible solutions to fix those vulnerabilities. The tool supports various types of scans including network scans, web application scans,

compliance checks, and configuration audits. Nessus is known for its fast scanning engine, accuracy in detecting vulnerabilities, and user-friendly web interface that allows users to easily schedule scans, monitor results, and manage security assessments. By continuously scanning and identifying potential risks, Nessus helps organizations improve their overall security posture, protect sensitive data, maintain system integrity, and comply with industry security standards and policies.

In addition, Nessus plays an important role in proactive cybersecurity management. Instead of waiting for cyberattacks to occur, organizations can use Nessus to regularly monitor their systems and identify weaknesses early. The tool provides comprehensive vulnerability analysis by comparing system configurations with known security standards and vulnerability databases such as the **Common Vulnerabilities and Exposures** list. This helps security teams stay informed about newly discovered threats and vulnerabilities. Nessus also supports scheduled scanning, allowing administrators to automatically run security scans at specific times without manual intervention. This ensures that systems are continuously monitored and updated against new threats. Another important capability of Nessus is its ability to provide detailed remediation guidance. After detecting vulnerabilities, the tool not only reports the issues but also suggests step-by-step solutions, such as installing patches, updating software versions, disabling insecure services, or strengthening security configurations.

Benefits of Nessus

1. **Early Detection of Vulnerabilities**
   Nessus helps organizations identify security weaknesses in systems, networks, and applications at an early stage. By detecting vulnerabilities before attackers exploit them, it reduces the risk of cyberattacks and data breaches.
2. **Improves Network Security**
   The tool continuously scans systems and identifies security gaps such as outdated software, weak configurations, and missing patches. This helps administrators strengthen the overall security of their network infrastructure.
3. **Comprehensive Vulnerability Coverage**
   Nessus uses a large and frequently updated plugin database that allows it to detect thousands of known vulnerabilities. This ensures that the system is checked against the latest security threats and risks.
4. **Detailed and Easy-to-Understand Reports**
   After completing a scan, Nessus generates detailed reports that show the vulnerabilities

detected, their severity levels, and recommended solutions. These reports help system administrators quickly understand and fix security issues.

5. **Automated Security Scanning**
   Nessus allows users to schedule automatic scans at regular intervals. This reduces manual effort and ensures that systems are regularly monitored for potential threats.

Target website :- http://testfire.net/

Target ip address:- 65.61.137.117

List of vulnerability

s.no	Vulnerability name	Severity	plugins
1	TLS Version 1.0 Protocol Detection	MEDIUM	104743
2	TLS Version 1.1 Protocol Deprecated	MEDIUM	157288
3	SSL/TLS Diffie-Hellman Modulus<= 1024 Bits (Logjam)	LOW	83875
4	ICMP Timestamp Request Remote Date Disclosure	INFO	10114
5	Additional DNS Hostnames	INFO	46180
6	Apache Tomcat Detection	INFO	39446
7	Common Platform Enumeration	INFO	45590
8	Device Type	INFO	54615

REPORT:-

1. Vulnerability Name:- - 104743 - TLS Version 1.0 Protocol Detection

severity : -MEDIUM

Plugin:- 104743

Port: - 443

Description:- The vulnerability **104743 – TLS Version 1.0 Protocol Detection** is identified by the vulnerability scanner **Nessus** when a system supports **Transport Layer Security version 1.0 for secure communications. TLS is a cryptographic protocol used to protect data transmitted over networks such as web browsing, email, and other online services. However, TLS 1.0 is an outdated protocol with several known security weaknesses. Modern security standards recommend using stronger versions such as **TLS 1.2** or **TLS 1.3**.

solution:- To resolve this vulnerability, organizations should disable TLS 1.0 on all servers, web services, and applications that support secure communications. System administrators should update server configurations to allow only secure protocols such as TLS 1.2 or TLS 1.3. This can usually be done by modifying web server settings (such as Apache, Nginx, or IIS) or updating operating system security policies. It is also recommended to keep all systems and applications updated with the latest security patches and ensure that weak encryption protocols are removed from the configuration. By implementing these changes, organizations can strengthen their encryption mechanisms and improve the overall security of their network communications.

Business Impact: If TLS 1.0 is enabled on a system, it may expose the organization to several security risks. Attackers could potentially exploit the weaknesses in the protocol to intercept or manipulate encrypted data transmitted between the server and users. This could lead to the exposure of sensitive information such as login credentials, financial data, or confidential business communications. Additionally, many modern security standards and compliance frameworks no longer allow the use of TLS 1.0. If organizations continue to use outdated encryption protocols,

they may face compliance violations, reputational damage, and potential financial losses due to data breaches or regulatory penalties.

2. Vulnerability Name:- 157288 - TLS Version 1.1 Protocol Deprecated

severity : - MEDIUM

Plugin:- 157288

Port:443

Description: The vulnerability **157288 – TLS Version 1.1 Protocol Deprecated** is detected by the vulnerability scanning tool **Nessus** when a server or system supports **Transport Layer Security version 1.1. TLS is a security protocol used to encrypt data transmitted over networks, ensuring confidentiality and integrity during communication between clients and servers. Although TLS 1.1 was introduced to improve security compared to earlier protocols, it is now considered outdated and has been deprecated by modern security standards. Most modern browsers, operating systems, and security frameworks recommend disabling TLS 1.1 and using stronger versions such as **TLS 1.2** or **TLS 1.3**. If a system still allows connections using TLS 1.1, it may be vulnerable to certain cryptographic weaknesses and may not provide the level of security required to protect sensitive data.

Solutions: To remediate this vulnerability, administrators should disable support for TLS 1.1 on all servers, applications, and network devices. System configurations should be updated to allow only secure and modern encryption protocols such as TLS 1.2 or TLS 1.3. This can be achieved by modifying the configuration settings of web servers, application servers, and operating systems. It is also recommended to regularly update software, apply security patches, and review encryption settings to ensure that only strong cryptographic protocols are enabled. By disabling TLS 1.1 and using newer protocols, organizations can significantly improve the security of their network communications and protect sensitive information from potential cyber threats.

Business impact: Allowing TLS 1.1 on servers can expose organizations to security risks because the protocol does not provide the strong encryption standards required by modern cybersecurity practices. Attackers may exploit weaknesses in outdated encryption protocols to intercept or manipulate sensitive data transmitted between users and servers. This may lead to the compromise of confidential information such as user credentials, financial data, or private communications. Additionally, many regulatory and compliance standards no longer support TLS 1.1. Organizations that continue using deprecated protocols may face compliance issues, security warnings from browsers, reputational damage, and possible financial losses due to security breaches.

3. Vulnerability Name:- - 83875 - SSL/TLS Diffie-Hellman Modulus <= 1024 Bits (Logjam)

Severity: -LOW

Plugin: 83875

Port: 443

Description: The vulnerability **83875 – SSL/TLS Diffie-Hellman Modulus ≤ 1024 Bits (Logjam)** is detected by the vulnerability scanning tool **Nessus** when a server supports weak **Diffie-Hellman key exchange parameters with a modulus size of 1024 bits or less during **Transport Layer Security or **Secure Sockets Layer communications. Diffie-Hellman is a key exchange method used in SSL/TLS protocols to securely establish encryption keys between a client and a server. However, when weak or small key sizes (1024 bits or lower) are used, the encryption becomes vulnerable to the **Logjam attack**.In the Logjam attack, an attacker can force a connection to use weak Diffie-Hellman parameters and potentially decrypt or intercept secure communications. This reduces the strength of encryption used to protect data transmitted over the network. As computing power increases, smaller key sizes become easier to break, making weak Diffie-Hellman parameters unsuitable for secure communication. Modern security standards recommend using stronger encryption mechanisms and larger key sizes to ensure the confidentiality and integrity of transmitted data.

Solution: To mitigate this vulnerability, administrators should disable weak Diffie-Hellman cipher suites and configure servers to use stronger cryptographic parameters. It is recommended to use Diffie-Hellman keys of at least **2048 bits** or stronger encryption methods such as **Elliptic Curve Diffie-Hellman**, which provide better security and performance. System administrators should also update server software, apply security patches, and ensure that modern TLS versions such as **TLS 1.2 or TLS 1.3** are enabled while disabling weak SSL/TLS protocols and cipher suites. By implementing stronger encryption configurations, organizations can significantly reduce the risk of cryptographic attacks and protect sensitive network communications.

Business impact: If a server uses weak Diffie-Hellman parameters, attackers may exploit this vulnerability to intercept or decrypt sensitive information transmitted between clients and servers. This could expose confidential data such as login credentials, financial transactions, personal information, or internal business communications. Exploitation of this vulnerability may lead to unauthorized access, data

breaches, and loss of customer trust. In addition, organizations that fail to implement strong encryption standards may face compliance violations, reputational damage, and financial losses due to security incidents or regulatory penalties.

4. Vulnerability Name: 10114 - ICMP Timestamp Request Remote Date Disclosure

Severity: -LOW

Plugin: 10114

Port:0

Description: The vulnerability **10114 – ICMP Timestamp Request Remote Date Disclosure** is detected by the vulnerability scanner **Nessus** when a remote host responds to **Internet Control Message Protocol timestamp requests. ICMP is a network protocol mainly used for diagnostic and error-reporting purposes in IP networks. The ICMP timestamp request feature allows a remote system to query another system to obtain its current system time. If a host responds to these requests, it reveals its system's date and time information to the requester. Although this vulnerability does not directly allow attackers to compromise the system, it may disclose information that can assist attackers in gathering details about the target system. This type of information disclosure can help attackers perform network reconnaissance and identify system characteristics. By knowing the exact system time, attackers may use the information to coordinate attacks, analyze system behavior, or attempt further exploitation of other vulnerabilities present in the network.

Solution: To remediate this issue, administrators should configure firewalls or network devices to block or disable ICMP timestamp requests and replies from external networks. This can typically be done by modifying firewall rules or system network configurations to prevent the system from responding to ICMP timestamp queries. Additionally, organizations should follow the principle of minimizing information disclosure by disabling unnecessary network services and protocols that are not required for normal operations. By restricting ICMP timestamp responses, organizations can reduce the amount of information exposed to potential attackers and improve overall network security.

Business impact: Allowing ICMP timestamp responses may expose system time information to unauthorized users on the network. This information could assist attackers in gathering intelligence about the network environment and planning targeted attacks. While the risk level is generally considered low,

information disclosure vulnerabilities can still contribute to larger security threats when combined with other vulnerabilities. Organizations may also want to minimize unnecessary information exposure to maintain a stronger security posture.

5. Vulnerability Name: 46180 - Additional DNS Hostnames

Severity: INFO

Plugin: 46180

Port: 0

Description : The vulnerability **46180 – Additional DNS Hostnames** is detected by the vulnerability scanning tool **Nessus** when a system is associated with multiple hostnames in the **Domain Name System**. DNS is responsible for translating human-readable domain names into IP addresses so that computers can locate and communicate with each other over a network. During the scanning process, Nessus performs DNS lookups and may discover additional hostnames that resolve to the same IP address as the target system.

Solution : Administrators should review all DNS records associated with the server and verify that each hostname is required and properly secured. Unnecessary or outdated DNS entries should be removed to reduce the exposure of the system. Additionally, organizations should ensure that all hostnames pointing to the server are protected with appropriate security controls, such as proper authentication, firewall restrictions, and updated software. Regular DNS audits and monitoring can also help identify unexpected or unauthorized hostnames associated with organizational systems.

Business impact: The discovery of additional DNS hostnames can increase the attack surface of an organization's infrastructure. If multiple hostnames point to the same server, attackers may attempt to access services using different domain names to find misconfigurations or unprotected applications. Some hostnames might expose development environments, test systems, or hidden services that are not intended for public access. This could lead to unauthorized access, information disclosure, or exploitation of vulnerabilities in exposed applications.

6.Vulnerability Name: 39446 - Apache Tomcat Detection

Severity: INFO

Plugin: 39446

Port: 0

Description : The vulnerability **39446 – Apache Tomcat Detection** is identified by the vulnerability scanning tool **Nessus** when it detects the presence of **Apache Tomcat** running on a target system. Apache Tomcat is a widely used open-source web server and servlet container developed by the **Apache Software Foundation** that is used to deploy and run Java-based web applications. During the scanning process, Nessus analyzes server responses, service banners, or web application characteristics to determine whether Apache Tomcat is installed and accessible on the host.

Solution: Administrators should verify the version of Apache Tomcat running on the server and ensure that it is updated to the latest stable and secure version. Regularly applying security patches and updates provided by the Apache Software Foundation can help protect against known vulnerabilities. Additionally, unnecessary services and default applications within Tomcat should be disabled or removed, and proper access controls should be implemented to restrict unauthorized access.

Business impact: The detection of Apache Tomcat on a server may reveal information about the technologies used in the organization's infrastructure. Attackers performing reconnaissance may use this information to search for known vulnerabilities associated with specific versions of Apache Tomcat. If the server is not properly configured, secured, or updated with the latest patches, attackers may exploit these vulnerabilities to gain unauthorized access, execute malicious code, or disrupt application services.

7. Vulnerability Name: 45590 - Common Platform Enumeration (CPE)

Severity: INFO

Plugin: 45590

Port: 0

Description: The **Common Platform Enumeration (CPE)** detection plugin in **Nessus vulnerability scanner** identifies and lists the standardized names of software, operating systems, and hardware platforms that are running on the scanned system. CPE is a standardized naming scheme developed by **National Institute of Standards and Technology (NIST)** to uniquely identify IT platforms. During the scanning process, Nessus analyzes the services, applications, and operating systems detected on the target system and assigns corresponding CPE identifiers. These identifiers help in accurately mapping the detected software to known vulnerabilities stored in vulnerability databases. By using CPE names, Nessus can perform more precise vulnerability matching and provide detailed information about the technology stack present on the scanned host.

Solution: Since this plugin is informational and not a vulnerability, no direct remediation is required. However, organizations should review the detected platform information and ensure that all software and operating systems are properly updated and patched to minimize security risks.

Business impact: The detection of CPE information allows security teams to clearly understand the software and platforms installed on a system. This helps in identifying potential vulnerabilities associated with those platforms and supports better asset management, vulnerability assessment, and compliance monitoring.

8.Vulnerability Name: - Device Type

Severity: - INFO

Plugin: - 54615

Port: - 0

Description: In **Nessus vulnerability scanner**, the **Device Type** detection identifies the category or type of device present on the scanned network host. During the scanning process, Nessus analyzes various characteristics of the target system such as open ports, running services, operating system information, and network behavior. Based on this information, it classifies the device into a specific type such as a server, workstation, router, printer, firewall, network device, or other system. This identification helps security administrators understand what kind of asset is connected to the network and how it should be managed or protected. The device type information is mainly used for asset discovery, network inventory, and improving vulnerability assessment accuracy.

Solution: Since **Device Type detection** in **Nessus vulnerability scanner** is an informational finding, no direct remediation is required. However, security administrators should review the identified device types to ensure that all devices connected to the network are authorized and properly managed. Organizations should maintain an updated asset inventory, apply appropriate security configurations for each device type, and ensure that all systems such as servers, routers, and workstations are regularly patched and monitored. Proper network segmentation and access control policies can also help manage different device types securely.

Business impact: The identification of device types helps organizations gain better visibility into their network infrastructure. By understanding what types of devices are present, security teams can apply suitable security policies and prioritize vulnerability management efforts. It also helps detect unauthorized or unknown devices on the network, which could pose potential security risks. Proper device classification improves asset management, enhances network monitoring, and supports better security decision-making within the organization.

Stage 3

Report

Title:- Implementing Zero Trust Network Access (ZTNA) with Zscaler: Securing User-to-Application Connectivity

- **ZERO TRUST NETWORK ACCESS(ZTNA)**

Zero Trust Network Access (ZTNA) is a modern cybersecurity approach that provides secure access to applications and services based on strict identity verification. It follows the principle **"Never Trust, Always Verify."** This means that no user, device, or system is trusted automatically, whether they are inside or outside the organization's network. Every access request must be authenticated, authorized, and continuously validated before permission is granted.

In traditional network security models, users inside the network are often trusted automatically once they log in through methods such as a Virtual Private Network (VPN). However, this approach can create security risks because attackers who gain access to the network may move freely within the system. ZTNA solves this problem by allowing users to access **only specific applications** instead of the entire network.

ZTNA works by verifying multiple factors such as the user's identity, device security status, location, and access policies. When a user requests access to an application, the ZTNA system checks these factors before granting permission. If the user meets all the security requirements, access is granted only to the requested application. The system also continuously monitors the user's activity to detect any suspicious behaviour

One of the key principles of ZTNA is **least privilege access**, which means users are given only the minimum level of access needed to perform their tasks. Another principle is **continuous monitoring**, where user activity is constantly checked to maintain security. ZTNA also uses **micro-segmentation**, which divides the network into smaller sections to prevent attackers from moving across the network if a breach occurs.
The benefits of ZTNA include stronger protection against cyberattacks, improved security for remote workers, better control over application access, and reduced risk of data breaches. It also helps organisations securely manage access for employees, partners, and third-party vendors.

ZSCALER THEN ENFORCES POLICIES BASED ON THIS DATA :

- User Identity Policies – Access is granted based on the verified identity of the user.

- Device Security Policies – Ensures the user's device meets security requirements (updated OS, antivirus, etc.).

- Application Access Control – Users are allowed to access only specific authorized applications, not the entire network.

- Location-Based Policies – Access permissions may depend on the user's geographic location or network.

- Multi-Factor Authentication (MFA) – Requires additional verification such as OTP or authentication apps for stronger security.

- Risk and Behavior Monitoring – Continuously monitors user activity and blocks suspicious behavior or potential threats.

NETWORK ACCESSING MODELS:

Network Accessing Models are methods or security approaches used to control how users and devices access a network or applications. These models help organizations manage security, authentication, and authorization when users connect to systems

1. Perimeter-Based Security Model

This is the **traditional network security model** where security is focused on protecting the network perimeter (boundary). Firewalls and VPNs are used to block unauthorized access from outside the network. Once a user enters the network, they are usually trusted.

Example:

Use of **Virtual Private Network (VPN)** to connect remote users to the company network.

2. Zero Trust Model

The **Zero Trust model** assumes that no user or device should be trusted automatically. Every access request must be verified before allowing access.

Example:

Zero Trust Network Access (ZTNA) checks user identity, device security, and policies before giving application access.

3. Role-Based Access Control (RBAC)

In this model, access is granted based on the **role of the user** in the organization. Different roles have different permissions.

Example:

An **HR employee** can access employee records, while an **IT administrator** can access system configurations.

4. Attribute-Based Access Control (ABAC)

Access decisions are based on **attributes** such as user identity, device type, location, time, or security status.

Example:

A user can access an application **only during office hours or from a secure device**.

5. Identity-Based Access Model

This model focuses on verifying the **identity of the user** before granting access. It uses authentication methods such as passwords, biometrics, or multi-factor authentication.

INCIDENT RESPONSE (ADAPTED FOR ZTNA):

Incident Response in a Zero Trust Network Access (ZTNA) environment is the process of detecting, responding to, and recovering from security incidents while using Zero Trust principles such as continuous verification and least-privilege access. In ZTNA systems, security teams monitor user activities, device status, and application access in real time to quickly identify suspicious behavior and prevent threats from spreading across the network.

The first step is Detection and Monitoring. ZTNA platforms continuously monitor user logins, device health, and application access. If unusual behavior is detected, such as access from an unknown device or location, the system generates alerts for the security team.

The second step is Analysis and Investigation. Security teams analyze logs, user identity information, device details, and access patterns to determine whether the activity is malicious. Because ZTNA provides detailed visibility into user and **application interactions,** it helps investigators quickly identify the source of the threat.

The third step is Containment. If a threat is confirmed, the ZTNA system can immediately block or restrict the affected user, device, or session. Access to applications can be revoked instantly to prevent attackers from moving further into the network.

The fourth step is Eradication and Recovery. The security team removes the threat by fixing vulnerabilities, resetting compromised credentials, and ensuring affected systems are secure. After the issue is resolved, normal access is restored based on security policies.

The final step is Post-Incident Review. The organization reviews the incident to understand what happened, how it was handled, and how to improve security policies. In ZTNA environments, this may include updating access rules, strengthening authentication, and improving monitoring systems.

Conclusion :-

In conclusion, exploring the realm of AI for web security using IBM QRadar has been an insightful journey through various stages.

In Stage 1: **Web Application Testing** is the process of **checking a web application to ensure it works correctly, securely, and efficiently before it is used by users**. It involves testing the website or web system to identify **bugs, errors, security vulnerabilities, and performance issues**.

Web application testing mainly focuses on verifying that all components of the application such as the **user interface, functionality, database, server, and security mechanisms** are working properly. The goal is to ensure that the web application provides a **smooth user experience, correct functionality, and strong protection against cyber threats**.

In web application testing, testers check whether all features such as **login forms, registration pages, data input forms, navigation links, and transactions** work correctly. They also verify that the application handles **invalid inputs, heavy traffic, and different browsers or devices** without failure.
Security is also an important part of web application testing. Testers check for vulnerabilities such as **SQL Injection, Cross-Site Scripting (XSS), and Broken Access**

In Stage 2 Nessus is a popular vulnerability scanning tool developed by Tenable that is widely used in the field of cybersecurity to identify security weaknesses in computer systems, networks, and applications. It scans devices and compares them with a large database of known vulnerabilities to detect potential security risks such as outdated software, open ports, weak configurations, and missing security patches. Nessus helps security professionals and organizations evaluate the security posture of their systems by providing detailed reports that include the description of vulnerabilities, their severity levels, possible business impacts, and recommended solutions.

The tool supports various types of scans, including network scanning, configuration auditing, and compliance checks, which help administrators maintain secure systems and follow security standards. Because of its regularly updated vulnerability database and easy-to-use interface, Nessus has become one of the most trusted tools for vulnerability assessment. - what you understand from the nessus report.

In Stage 3 Security Operations Center (SOC), Security Information and Event Management (SIEM), and the IBM QRadar Dashboard work together to help organizations monitor, detect, and respond to cybersecurity threats in real time.

A SOC is a centralized team responsible for continuously monitoring an organization's network, systems, and applications for suspicious activities. SIEM is the technology used by the SOC to collect, analyze, and correlate security logs and events from multiple sources such as servers, firewalls, and applications.

The IBM QRadar dashboard is a visualization interface that displays security alerts, threats, network activity, and event logs in an organized and easy-to-understand format. It helps security analysts quickly identify unusual behavior, investigate incidents, and take action to prevent cyber attacks.

Future Scope

Future scope of web application testing :

The future scope of Web Application Testing is very significant because web applications are becoming more complex and widely used in areas such as banking, e-commerce, healthcare, and education. As businesses increasingly depend on web applications, the need for high-quality, secure, and reliable testing will continue to grow.

One major future development is the use of automation in testing. Automated testing tools help testers quickly identify bugs, reduce manual effort, and improve testing efficiency. Automation allows continuous testing during the development process, which helps developers release applications faster.

Another important area is security testing. With the rise in cyberattacks such as SQL injection, cross-site scripting (XSS), and data breaches, organizations will focus more on securing web applications. Security testing will play a major role in identifying vulnerabilities and protecting sensitive user information.

The integration of Artificial Intelligence (AI) and Machine Learning (ML) in testing is also growing. AI-based testing tools can automatically detect errors, predict failures, and improve the testing process by learning from previous test results.

In addition, cloud-based testing is becoming more popular. Cloud platforms allow testers to test web applications across different devices, browsers, and operating systems without needing expensive hardware. This improves scalability and flexibility.
Another future trend is continuous testing in DevOps environments, where testing is integrated into the development lifecycle. This ensures that web applications are tested frequently and issues are detected early.

Future scope of testing process you understood:

The future scope of the testing process using Nessus is very significant as organizations increasingly rely on digital systems and networks. As cyber threats continue to grow and evolve, vulnerability scanning tools like Nessus vulnerability scanner, developed by Tenable, will play a crucial role in strengthening cybersecurity practices. In the future, Nessus is expected to integrate more advanced technologies such as automation, artificial intelligence, and machine learning to improve vulnerability detection and reduce false positives. It will also support broader environments including cloud infrastructure, Internet of Things (IoT) devices, and hybrid networks, enabling organizations to perform more comprehensive security assessments. Additionally, the testing process will become faster and more efficient with real-time monitoring and continuous vulnerability assessment, helping security teams identify and fix issues immediately. As regulatory compliance and data protection requirements increase, Nessus will also provide enhanced compliance checks and detailed reporting features. Overall, the future scope

of Nessus testing lies in providing smarter, automated, and more scalable vulnerability management solutions to protect modern digital infrastructures.

Future scope of SOC / SEIM

The future scope of **Security Operations Center (SOC)** and **Security Information and Event Management (SIEM)** is rapidly growing because organizations are increasingly facing cyber threats and data breaches. SOC teams are responsible for continuously monitoring networks, systems, and applications to detect and respond to security incidents. SIEM technologies help collect and analyze security logs from multiple sources to identify suspicious activities in real time.

In the future, SOC and SIEM will rely more on **automation, artificial intelligence (AI), and machine learning** to detect threats faster and reduce the workload of security analysts. Automated threat detection and response systems will help organizations quickly identify vulnerabilities, stop attacks, and improve overall security management. Cloud security monitoring and integration with advanced security tools will also become more common.

SOC environments will continue to evolve with better **threat intelligence, behavioral analytics, and real-time monitoring systems**. These improvements will allow security teams to proactively detect attacks before they cause serious damage.

Topics Explored

- SOC architecture and working process
- Log monitoring and event analysis
- Threat detection and incident response
- Security alerts and risk analysis
- Network and system monitoring

Tools Explored

- **IBM QRadar**
- **Splunk Enterprise Security**
- **Elastic SIEM**
- **ArcSight**

—--------THE END —----------